

Audit de cybers curit  de code logiciel par IA dans un environnement ma tris 

Version 1.3 une plateforme IA locale, op r e dans une enclave europ enne ma tris e, avec des interactions Internet filtr es en entr e et en sortie.

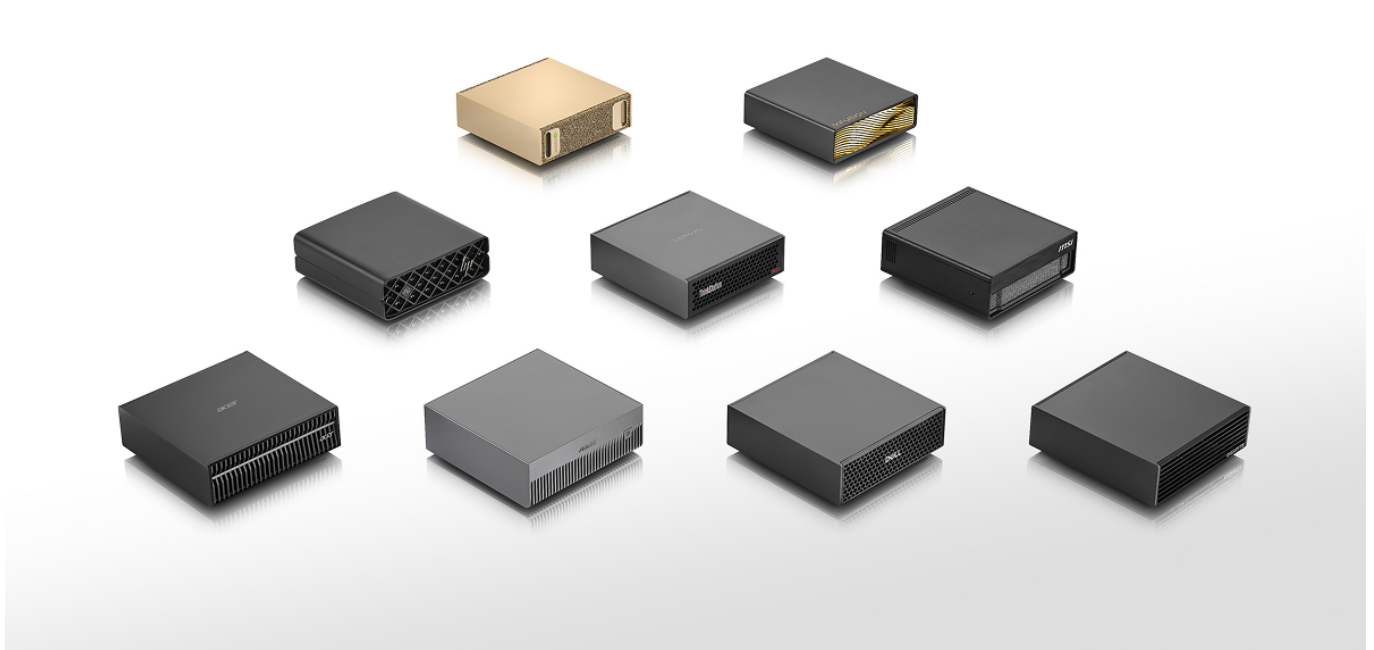
BlueTrusty propose une analyse de s curit  du code logiciel mis  sa disposition par le client. L'objectif est d'identifier les vuln rabilit s et les sc narios de risque qui m ritent une correction ou une investigation compl mentaire, puis de les restituer dans un rapport exploitable.

Le code source, les d pendances, les configurations et la documentation utile sont  tudi s dans une enclave situ e en Union europ enne. Le mat riel IA mobilis  est r serv   cette fonction. L'analyse ne repose pas sur un service d'IA cloud mutualis .

Une plateforme matérielle dédiée

Selon le volume du périmètre, l'enclave s'appuie sur des capacités NVIDIA, notamment des puces Blackwell ou des châssis DGX. Les ressources sont réservées à audit et intégrées à l'enclave, sans recours à un service d'IA mutualisé.

Les interactions éventuellement nécessaires avec Internet passent par un sas de sécurité et d'inspection dédié. Les destinations autorisées relèvent d'une liste blanche stricte et tous les échanges qui traversent ce sas sont journalisés.



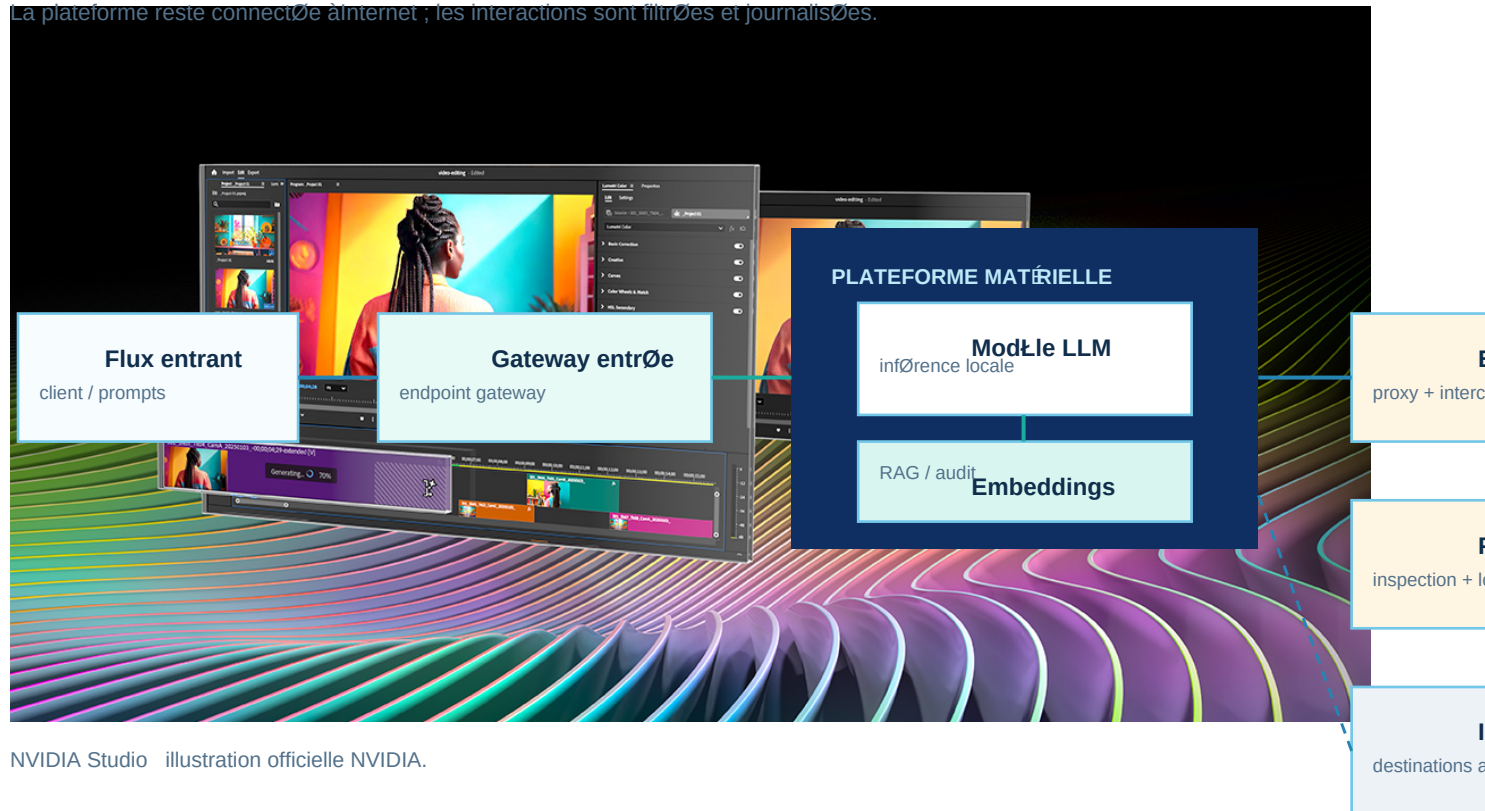
NVIDIA DGX Spark illustration officielle NVIDIA.

Studio et mØmoire d audit

Tous nos rapports d audit et travaux de recherche sont anonymisØs, puis conservØs dans un espace de stockage raw dØdiØ et indexØs dans une base de connaissances de type RAG (Retrieval-Augmented Generation).

Flux contrØs autour du modØle LLM

La plateforme reste connectØe à internet ; les interactions sont filtrØes et journalisØes.



NVIDIA Studio illustration officielle NVIDIA.

ContrØs de frontiØre

liste blanche • inspection • journalisation • pas d exfiltration non autorisØe

EntrØe : gateway endpoint

Sortie : egress gateway + proxy avec interception et filtrage des logs

D roul  de l audit

Contexte

BlueTrusty propose une analyse de s curit  du code logiciel mis  sa disposition par le client. L objectif est d identifier les vuln rabilit s et les sc narios de risque qui m ritent une correction ou une investigation compl mentaire, puis de les restituer dans un rapport exploitable.

L intervention s adresse notamment aux applications m tier, aux API, aux composants expos s, aux produits en pr paration et aux patrimoines logiciels qui concentrent des enjeux de confidentialit  ou de disponibilit .

Elle est particuli rement adapt e aux organisations qui ne souhaitent pas exposer leur base de code  des services externes, afin de pr server la confidentialit  et leur propri t  intellectuelle. Elle r pond aussi aux cas o  l usage d outils d IA en cloud reste inacceptable, y compris lorsque ces outils proposent une configuration ZDR, ou *Zero Data Retention*.

Ces pr occupations rejoignent la controverse r cente autour de travaux math matiques non publi s et des conditions dans lesquelles OpenAI aurait pu en avoir connaissance. Les faits sont contest s, mais cet  pisode rappelle l importance de ma triser pr cis ment o  circulent le code, les  changes et les r sultats de recherche.

Un audit de code adapt  aux environnements sensibles

Le code source, les d pendances, les configurations et la documentation utile sont  tudi s dans une enclave situ e en Union europ enne. Le mat riel IA mobilis  est r serv   cette fonction. L analyse ne repose pas sur un service d IA cloud mutualis . En aucun cas, une partie du code ne sera exfiltr e ni transmise  une IA ou  tout autre service ext rieur   l enclave.

Notre environnement d audit n est pas une plateforme multi-tenante ni un espace de travail partag  entre plusieurs clients.  un moment donn , chaque enclave est d di e   l analyse du code, des d pendances et des configurations d un seul client, dans un environnement isol  et contr  . Les flux entrants sont plac s sous le contr e d une architecture r seau ZTNA. Les flux sortants sont journalis s au niveau applicatif au moyen d une interception TLS effectu e localement. Le mod le ne dispose d aucun chemin de sortie alternatif : toute communication vers l ext rieur doit passer par le proxy d interception, selon les r gles autoris es et journalis es. Cette conception s inspire des principes NVIDIA relatifs aux environnements d ex cution isol s,   la s paration des workloads et au contr e des flux sortants.

Le p rim tre de l audit cyber de code est d fini avant le transfert. Les modalit s de remise, les r gles de manipulation et le canal de restitution sont convenus avec le client afin de s aligner sur ses contraintes de confidentialit .

Selon le volume du p rim tre, l enclave s appuie sur des capacit s NVIDIA, notamment des puces Blackwell ou des ch ssis DGX. Elle peut utiliser du mat riel d j  tenu par BlueTrusty et exploit  dans un environnement cloisonn  et ma tris . Elle peut aussi recourir   la location   l heure de capacit s mat rielles brutes aupr s d op rateurs d infrastructure en tant que service (IaaS), soit qualifi s SecNumCloud, soit h bergeant ces capacit s dans l Union europ enne. Dans ce cas, les ressources sont r serv es   l audit et int gr es   l enclave, sans recours   un service d IA mutualis . Le choix de l infrastructure, de l op rateur et des modalit s d exploitation est pr sent  au client et valid  par lui avant tout audit.

Les interactions  ventuellement n cessaires avec Internet, par exemple pour consulter une documentation technique ou t l charger un outil sp cifique, passent par un sas de s curit  et d inspection d di . Les destinations autoris es rel vent d une liste blanche stricte et particuli rement surveill e. Tous les  changes qui traversent ce sas sont journalis s. Ce contr e des flux sortants vise   pr venir toute transmission non autoris e de code, de donn es ou de propri t  intellectuelle hors de l enclave.

Une plateforme d'IA spécialement entraînée pour l'analyse de code logiciel

Les vulnérabilités se révèlent souvent dans les relations entre composants plutôt que dans une instruction isolée. L'analyse examine donc les flux de données, les contrôles d'accès, les secrets, les dépendances et les hypothèses de configuration qui peuvent former un chemin d'attaque plausible.

Plusieurs agents spécialisés travaillent en parallèle sur les zones les plus pertinentes du périmètre. Cette organisation permet de traiter de grandes bases de code sans limiter l'investigation à quelques fichiers ou à une lecture séquentielle.

Le harnais qui orchestre l'audit est open source. Il n'est pas fourni par l'éditeur du modèle de langage utilisé, ce qui permet de maîtriser séparément l'orchestration de l'analyse et le choix du modèle.

Le dispositif utilise du matériel IA de dernière génération et un modèle front-end de type MoE à poids ouverts (*open weight*), fine-tuné à partir de nos audits anonymisés et d'une documentation cybersécurité sélectionnée.

Tous nos rapports d'audit et travaux de recherche sont anonymisés, puis conservés dans un espace de stockage raw dédié et indexés dans une base de connaissances de type RAG (*Retrieval-Augmented Generation*). Cette base est mise à la disposition du LLM à l'intérieur de l'enclave. Pendant l'investigation, le modèle retrouve les analyses, scénarios de risque et pistes de correction pertinents issus de cette expérience accumulée. Le fine-tuning adapte ses capacités ; le RAG lui apporte des connaissances consultables au moment de l'audit, ce qui renforce la portée du moteur d'audit cyber. Nos équipes d'experts rapprochent, contextualisent et structurent ensuite les résultats produits par les agents pour former une vue cohérente des risques.

Déroulé de l'audit

L'audit s'appuie sur les cadres méthodologiques et les référentiels du NIST, de MITRE et de l'OWASP, sélectionnés selon la nature du logiciel examiné. Ils guident la conduite de l'investigation, la classification des faiblesses et la vérification des contrôles de sécurité applicables.

Cadrage. Définition du périmètre, des composants sensibles, des hypothèses de menace et des attentes de restitution.

Cartographie et planification. Lecture de l'architecture, des frontières de confiance, des dépendances et des flux qui portent les données sensibles.

Investigation. Recherche des faiblesses et des enchaînements qui pourraient être exploités dans le contexte applicatif.

Qualification. Mise en perspective de chaque constat selon son impact potentiel, sa plausibilité et sa priorité de traitement.

Restitution. Présentation des résultats aux décideurs et aux équipes techniques afin de préparer les remédiations.

L'équipe BlueTrusty construit l'environnement de test avant l'audit, puis le démantèle de façon sécurisée à l'issue de la mission. Elle assure les échanges avec le client, conduit les entretiens nécessaires et présente les résultats. Elle analyse et qualifie les rapports produits avec l'assistance de l'IA : les conclusions reposent ainsi sur une lecture argumentée, supervisée et assumée par l'équipe.

Un rapport conçu pour la décision et la correction

Le rapport, réalisé avec l'assistance de l'IA dans cet environnement maîtrisé, distingue les constats selon leur niveau de priorité. Pour chacun, il précise le contexte concerné, le scénario de risque, l'impact potentiel, les éléments de preuve utiles et une orientation de remédiation. Une synthèse facilite les arbitrages de pilotage, tandis que les équipes techniques disposent des informations nécessaires pour organiser les corrections.

Des annexes techniques détaillées accompagnent le rapport. Elles peuvent notamment présenter des propositions de correction de code, afin d'aider les équipes à préparer et à accélérer les remédiations.

Une restitution permet ensuite d'échanger sur les conclusions, de préciser les points sensibles et de définir les prochaines étapes.

Cadre, limites et référentiels

L'IA apporte une capacité d'exploration adaptée aux périmètres étendus et accélère l'investigation. Le service ne constitue pas une certification du logiciel ni une garantie d'absence de vulnérabilité. Les résultats sont communiqués dans le cadre précis du périmètre audité et des éléments mis à disposition.

Les référentiels méthodologiques mentionnés dans cette offre sont accessibles ici :

NIST SP 800-115: Technical Guide to Information Security Testing and Assessment

NIST SP 800-218: Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities

MITRE CWE: Common Weakness Enumeration

MITRE CAPEC: Common Attack Pattern Enumeration and Classification

OWASP Code Review Guide

OWASP Application Security Verification Standard (ASVS)

NVIDIA Enterprise Reference Architectures

À propos de bluetrusty.ai

BlueTrusty est certifié ISO 27001. Son approche des infrastructures IA maîtrisées est présentée dans les formations et l'article suivants :

Formation ORSYS : Plateforme IA d'entreprise, construire une architecture hybride

Formation Institut Capgemini : construire sa plateforme IA d'entreprise souveraine et maîtrisée

Article ChannelNews : ITS Group formalise une offre d'accompagnement à la construction de plateformes IA souveraines